

HANDOVER DOCUMENT

Business OS (CoalTradeOS)

Internal Business Management Platform
Coal Trading Operations Suite

Version 1.0.0

Tanggal: 06 Mei 2026

Status: Production Ready

DAFTAR ISI

1. Ringkasan Eksekutif
2. Tech Stack & Arsitektur
3. Struktur Project
4. Database Schema
5. Modul & Fitur Aplikasi
6. Autentikasi & RBAC
7. API Endpoints
8. Integrasi Eksternal
9. Deployment & Infrastructure
10. Keamanan
11. Panduan Developer Baru
12. Known Issues & Backlog

1. RINGKASAN EKSEKUTIF

Business OS (CoalTradeOS) adalah platform manajemen bisnis internal berbasis web untuk operasional perusahaan perdagangan batu bara. Mengintegrasikan sales monitoring, shipment tracking, quality control, market price intelligence, dan financial forecasting dalam satu dashboard.

1.1 Tujuan Sistem

- Single source of truth untuk seluruh data operasional
- Real-time shipment monitoring (MV Barge & Daily Delivery)
- Market price tracking (ICI 1-5, Newcastle, HBA)
- Sales pipeline, purchase requests, P&L forecast
- AI chatbot, risk analysis, meeting transcription
- RBAC untuk 27 posisi organisasi

1.2 Status

- Production-ready, deployed via VPS + Neon PostgreSQL
- Database-First Mode (Google Sheets optional)
- 2,000+ records historis dimigrasikan dari Excel

2. TECH STACK & ARSITEKTUR

2.1 Frontend

Teknologi	Versi	Keterangan
Next.js	14.x	App Router, SSR/CSR
React	18.x	UI library
TypeScript	5.x	Type-safe
TailwindCSS	3.x	Utility CSS
Zustand	5.x	State management
Recharts	2.x	Charts
next-auth	4.x	Auth (JWT)
Lucide React	-	Icons

2.2 Backend & Database

Teknologi	Versi	Keterangan
Next.js API Routes	-	REST API
Prisma ORM	5.22	Type-safe ORM
PostgreSQL (Neon)	-	Production DB
SQLite	-	Dev DB
bcryptjs	-	Password hashing
googleapis	-	Sheets integration

2.3 AI & Integrations

Service	Kegunaan
Groq API	Chatbot & Transcription
OpenRouter	AI Agent & Risk Analysis
Twilio	WhatsApp notification
Google Sheets API	Export/backup
jsPDF	PDF generation

3. STRUKTUR PROJECT

Path	Deskripsi
src/app/	Next.js App Router pages & API
src/app/api/	Backend API endpoints
src/app/page.tsx	Executive Dashboard (98KB)
src/components/	React components
src/lib/	Utilities (auth, rbac, prisma, scraping)
src/store/	Zustand stores (9 files)
src/types/	TypeScript definitions
src/hooks/	Custom hooks
src/middleware.ts	Route protection
prisma/schema.prisma	DB schema (20 models, 27 roles)
scripts/	Migration & utility scripts
public/	Static assets

3.1 Zustand Stores

File	Fungsi
commercial-store.ts	Master store (73KB) — shipments, deals, prices, meetings
auth-store.ts	Session & user state
task-store.ts	Task/kanban management
sales-store.ts	Sales orders
purchase-store.ts	Purchase requests
daily-delivery-store.ts	Daily delivery CRUD
directory-store.ts	Partner directory
outstanding-payment-store.ts	Payment tracking
ui-store.ts	UI state

4. DATABASE SCHEMA

Prisma ORM + PostgreSQL. 20 models, enum UserRole (27 roles). File: prisma/schema.prisma

Model	Deskripsi
User	Akun + role + relasi chat/audit
ChatHistory	Chat AI per user (isolated)
TaskItem	Kanban tasks
SalesOrder	Sales orders + approval
PurchaseRequest	Purchase + OCR + anomaly
ShipmentDetail	Shipment MV/Barge (40+ kolom, risk fields)
DailyDelivery	Laporan harian (40+ kolom)
SourceSupplier	Supplier/tambang + spec
QualityResult	Sampling kualitas (GAR, TS, Ash, TM)
MarketPrice	Harga pasar (ICI, HBA, HPB)
OutstandingPayment	Payment tracking
MeetingItem	Meeting + AI MOM
MeetingMedia	Media files + transcription
PLForecast	P&L forecast per deal
SalesDeal	Sales pipeline
ProjectItem	Project + approval
Partner	Buyer & vendor
BlendingSimulation	Blending simulator
AuditLog	Audit trail
SyncState	Sync state tracking

5. MODUL & FITUR APLIKASI

Route	Deskripsi	Akses
/	Executive Dashboard	CEO, DIRUT, COO
/sales-monitor	Sales pipeline	CMO, Traders
/sales-orders	Sales order CRUD	Traders, Admin Marketing
/shipment-monitor	Shipment tracking + risk analysis	Traffic, Admin Op
/market-price	Harga pasar + HPB calculator	All commercial
/pl-forecast	P&L forecast	Traders, CMO
/outstanding-payment	Payment tracking	Admin Op, Traffic Head
/sources	Supplier database	Sourcing Team
/quality	Quality results (COA)	QC Team
/blending	Blending simulation	QC, Sourcing
/purchase-requests	Purchase + anomaly	All (role-based)
/projects	Project management	CPPO, Traders
/meetings	Meeting + AI MOM	All roles
/directory	Partner database	Admin, Sourcing
/my-tasks	Personal tasks	All roles
/all-tasks	Global kanban	Manager+
/audit-logs	Audit trail	CEO, DIRUT
/users	User management	Admin

6. AUTENTIKASI & RBAC

6.1 Authentication

- NextAuth.js v4, Credentials Provider, JWT strategy
- Password hashing: bcryptjs
- Middleware: route protection + role-based redirect
- Dashboard (/) restricted to CEO, DIRUT, ASS_DIRUT, COO

6.2 RBAC Modules (src/lib/rbac.ts)

Module	Cakupan	Roles
PL_SALES	P&L + Sales Monitor	Traders, CMO, Admin Marketing
OPERATIONS_TRAFFIC	Shipment + Transshipment	Traffic, Admin Op, QC
QUALITY_BLENDING	Quality + Blending	QC Team, Sourcing
SOURCING	Sourcing + Purchase	Sourcing Team, Traders
MARKET_PRICE	Market Price	Traders, Admin, Sourcing
DIRECTORY	Vendors/Clients	Admin, Sourcing, Traders
OUTSTANDING_PAYMENT	Payments	Admin Op, Traffic Head

Permission levels: read, write, approve. Functions: canReadModule(), canWriteModule(), canApproveModule().

27 roles didefinisikan dalam enum UserRole: CEO, DIRUT, ASS_DIRUT, COO, CMO, CPPO, QQ_MANAGER, ADMIN_OPERATION, TRADERS_1-4, JUNIOR_TRADER, TRAFFIC_HEAD, TRAFFIC_TEAM_1-4, ADMIN_MARKETING, QC_MANAGER, QC_ADMIN_1-2, SPV_SOURCING, SOURCING_OFFICER_1-4, STAFF.

7. API ENDPOINTS

Endpoint	Deskripsi
/api/auth/[...nextauth]	Login/logout/session
/api/chat	AI chatbot (Groq/OpenRouter)
/api/chat/history	Chat history per user
/api/memory/*	CRUD semua entitas bisnis
/api/sheets/*	Google Sheets sync
/api/shipments/{id}/risk-analysis	AI risk analysis
/api/market-scrape	Market price scraping
/api/transcribe	Audio transcription (Whisper)
/api/upload	File upload
/api/maintenance/sync	Sheets export
/api/users	User management
/api/whatsapp/send	WhatsApp sender (Twilio)
/api/whatsapp/webhook	Twilio webhook

MOM Service (External)

Separate Go/Node service untuk Minutes of Meeting. Base: <http://localhost:8080>. Endpoints: [/api/v1/mom/upload-video](#), [/api/v1/mom/jobs/{id}](#), [/api/v1/mom/pdf/{filename}](#).

8. INTEGRASI EKSTERNAL

8.1 Google Sheets (Optional)

Database-First Mode aktif sejak April 2026. Sheets hanya untuk export/backup. Memor Sheets.

8.2 AI Integration

- Groq: Chatbot & audio transcription (Whisper)
- OpenRouter: AI agent, risk analysis, market intelligence
- Risk Analysis: Analisis cuaca, berita, kondisi laut per shipment

8.3 WhatsApp (Twilio)

Notifikasi otomatis via Twilio. Send: /api/whatsapp/send. Webhook: /api/whatsapp/webhook.

8.4 Data Migration

Migrasi Excel! DB via scripts/. Sumber: MV_Barge&Source (2021-2024), Daily Delivery

9. DEPLOYMENT & INFRASTRUCTURE

9.1 Environment Variables

Variable	Deskripsi	Status
DATABASE_URL	PostgreSQL (Neon)	Required
DIRECT_URL	Direct DB connection	Required
NEXTAUTH_SECRET	JWT secret	Required
NEXTAUTH_URL	App base URL	Required
GROQ_API_KEY	Groq AI key	Optional
GOOGLE_SHEETS_ID	Spreadsheet ID	Optional
GOOGLE_SHEETS_CREDENTIALS	GCP service account	Optional

9.2 Deployment Steps

- 1. git clone + npm install
- 2. `.env.example !' .env (isi required vars)`
- 3. `npx prisma generate && npx prisma db push`
- 4. `npx prisma db seed` (optional)
- 5. `npm run build`
- 6. `pm2 start npm --name business-os -- start`

9.3 Server

Script `setup-server.sh`: Ubuntu 22/24 LTS, Node 20, PM2, Nginx reverse proxy, UFW firewall, SSL via Certbot.

Production URL: <https://production.sangkaraprasetya.site>

10. KEAMANAN

SAST audit 18 Maret 2026: 5 High, 8 Medium, 5 Low findings.

10.1 Critical Findings

#	Temuan	Status
1	Secret exposure di .env (git history)	Rotasi semua secret
2	Auto-create CEO tanpa safeguard	FIXED
3	Fallback NEXTAUTH_SECRET hardcoded	FIXED
4	Path Traversal pada file upload	Perlu perbaikan
5	LFI pada transcribe endpoint	Perlu perbaikan

10.2 Positif

- Audit logging konsisten (Prisma transaction)
- Soft delete (isDeleted)
- bcrypt password hashing
- JWT stateless session
- Prisma ORM (SQL injection prevention)

11. PANDUAN DEVELOPER BARU

Prerequisites

- Node.js v20+, npm, PostgreSQL/Neon, Git

Quick Start

- 1. `git clone <repo> && npm install`
- 2. `Copy .env.example !' .env`
- 3. `npx prisma generate && npx prisma db push`
- 4. `npm run dev !' http://localhost:3000`

Konvensi

- TypeScript strict mode
- Zustand: 1 store per domain
- API: App Router `route.ts` convention
- Semua CRUD: include audit logging
- Soft delete only (`isDeleted` flag)
- RBAC check di setiap endpoint & component

Key Files

- `src/store/commercial-store.ts` (73KB) — master state
- `src/app/page.tsx` (98KB) — executive dashboard
- `src/lib/rbac.ts` — permission matrix
- `src/lib/auth.ts` — NextAuth config
- `prisma/schema.prisma` — database schema

12. KNOWN ISSUES & BACKLOG

12.1 Known Issues

Severity	Issue	Action
HIGH	Chat/WhatsApp endpoint tanpa auth	Add session check
HIGH	IDOR — no ownership validation	Add ownership check
MEDIUM	NEXT_PUBLIC_ API key exposed	Remove prefix
MEDIUM	No rate limiting	Add rate limiter
MEDIUM	No prompt injection protection	Add sanitization
LOW	Market data dari LLM (bukan real API)	Integrate real API
LOW	Missing pagination pada beberapa query	Add server-side pagination

12.2 Feature Backlog

- AI Risk Analysis: Real API integration (NewsAPI, Stormglass, BMKG)
- Row-Level Security per user assignment
- WebSocket real-time notifications
- Mobile responsive optimization
- Automated PDF report generation
- Integration testing suite

Untuk pertanyaan teknis, hubungi tim development. Dokumentasi tambahan: RBAC_Documentation.md, REQUIREMENT_SYSTEM_COMPLETE.md, API_USAGE.md, sast_security_report.md.